

DOCUMENT TECHNIQUE — CONFORMITÉ RGPD

Politique de Confidentialité

CYNA Security Platform — Conformité RGPD (Règlement UE 2016/679)

BC3 — CPI Bachelor DEV Full Stack 2025-2026

AUTEUR

Omar AKAKBA (Back-End)

VERSION

1.0 — Juillet 2026

RESPONSABLE DU TRAITEMENT

CYNA Security (projet pédagogique)

HÉBERGEMENT

Alwaysdata — France

1. Présentation du responsable du traitement

Dans le cadre de ce projet pédagogique, le responsable du traitement des données est :

- **Nom** : CYNA Security (projet pédagogique BC3)
- **École** : INGETIS / SUP DE VINCI — Promotion 2025-2026
- **Développeur back-end** : Omar AKAKBA
- **Hébergement** : Alwaysdata SAS, 91 rue du Faubourg Saint-Honoré, 75008 Paris (France)
- **URL de la plateforme** : <https://omar05.alwaysdata.net/cyna/>

2. Données collectées et finalités

La plateforme CYNA collecte les données strictement nécessaires au fonctionnement du service (principe de minimisation — article 5(1)(c) RGPD) :

Catégorie de données	Données collectées	Finalité	Base légale	Durée de conservation
Identité	Prénom, nom, adresse e-mail	Création et gestion du compte	Contrat (art. 6(1)(b))	Durée du compte + 3 ans
Authentification	Mot de passe (hash bcrypt), token remember_me (hash SHA-256)	Connexion sécurisée	Intérêt légitime (art. 6(1)(f))	Durée de session / 30 jours (cookie)
Commandes	Produits commandés, montant, statut, référence Stripe	Exécution du contrat, facturation	Contrat (art. 6(1)(b))	10 ans (obligations comptables)
Adresses	Adresse de facturation complète	Livraison et facturation	Contrat (art. 6(1)(b))	Durée du compte
Logs de sécurité	IP, horodatage des tentatives de connexion	Protection contre les attaques brute-force	Intérêt légitime (art. 6(1)(f))	15 minutes (effacement automatique)
Messages de contact	Nom, e-mail, message	Traitement des demandes support	Consentement (art. 6(1)(a))	1 an

3. Base légale des traitements

Conformément à l'article 6 du RGPD, les traitements reposent sur les bases légales suivantes :

- **Art. 6(1)(a) — Consentement** : acceptation obligatoire des CGU lors de l'inscription (case à cocher, non pré-cochée). Le consentement est traçable par le champ `cgu_accepted` (booléen) en base de données.

- **Art. 6(1)(b) — Exécution d'un contrat** : traitement des commandes, paiements via Stripe Checkout, facturation, gestion des adresses.
- **Art. 6(1)(f) — Intérêt légitime** : sécurisation de la plateforme (rate limiting, logs de connexion, protection CSRF/XSS).

4. Droits des personnes concernées

Conformément aux articles 15 à 22 du RGPD, les utilisateurs disposent des droits suivants, entièrement implémentés dans la plateforme :

Article RGPD	Droit	Implémentation technique	Accès utilisateur
Art. 15	Droit d'accès	Espace client avec affichage des commandes, profil et adresses	<code>/cyna/espace-client.php</code>
Art. 16	Droit de rectification	Modification du profil (prénom, nom, e-mail, mot de passe) via formulaire sécurisé (CSRF + validation)	<code>/cyna/profil.php</code>
Art. 17	Droit à l'effacement	Suppression du compte utilisateur avec anonymisation des commandes (<code>user_id = NULL</code>) pour respecter les obligations comptables. Suppression en cascade des adresses.	<code>/cyna/profil.php</code> → Bouton "Supprimer mon compte"
Art. 20	Droit à la portabilité	Export de toutes les données personnelles en format JSON téléchargeable (profil, commandes, adresses)	<code>/cyna/export-donnees.php</code>
Art. 25	Privacy by design	Principe de minimisation dès la conception : seules les données nécessaires sont collectées. <code>order.user_id NULLABLE</code> pour permettre l'anonymisation.	Intégré au schéma BDD (<code>sql/schema.sql</code>)
Art. 32	Sécurité des données	Chiffrement des mots de passe (bcrypt <code>cost=12</code>), HTTPS en production, tokens CSRF, rate limiting, requêtes préparées PDO	<code>includes/security.php</code> , <code>includes/auth.php</code>
Art. 7	Consentement	Case à cocher CGU lors de l'inscription (non pré-cochée). Lien vers CGU complètes.	<code>/cyna/inscription.php</code>

5. Mesures techniques de sécurité

Conformément à l'article 32 RGPD (sécurité du traitement), les mesures suivantes sont implémentées :

5.1 Protection des mots de passe

- Algorithme : **bcrypt** via `password_hash($password, PASSWORD_BCRYPT, ['cost' => 12])`
- Vérification : `password_verify()` — résistant aux attaques de timing

- Les mots de passe en clair ne sont **jamais** stockés ni loggués

5.2 Protection contre les injections SQL

- Toutes les requêtes utilisent des **requêtes préparées PDO** avec `execute([])`
- Aucune concaténation directe de variables dans les requêtes SQL
- Exemple : `$stmt = $db->prepare('SELECT * FROM user WHERE email = ?'); $stmt->execute([$email]);`

5.3 Protection CSRF

- Tous les formulaires POST incluent un token CSRF : `bin2hex(random_bytes(32))`
- Validation par `hash_equals()` — résistant aux attaques de timing
- Token stocké en session, invalidé après utilisation

5.4 Protection XSS

- Toutes les sorties HTML passent par `htmlspecialchars($val, ENT_QUOTES, 'UTF-8')`
- En-têtes de sécurité : `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Content-Security-Policy`

5.5 Rate limiting (anti-brute-force)

- Maximum **5 tentatives de connexion par IP sur 15 minutes**
- Stocké en base de données (table `rate_limit`) — nettoyage automatique après expiration
- Alertes Grafana si ≥ 5 tentatives en 5 minutes (niveau Critical)

5.6 Tokens de session

- Régénération de l'ID de session après chaque connexion : `session_regenerate_id(true)`
- Cookie "remember me" : token aléatoire (32 octets) stocké hashé en SHA-256 en BDD
- Attributs du cookie : `httponly: true`, `samesite: Lax`

6. Anonymisation des données lors de la suppression

Lors de la suppression d'un compte (art. 17 RGPD), le processus est le suivant :

1. Les **adresses de facturation** sont supprimées en cascade (`ON DELETE CASCADE`)
2. Les **commandes** sont conservées (obligations comptables — art. L123-22 Code de commerce) mais anonymisées : `user_id = NULL` (colonne `NULLABLE` avec `ON DELETE SET NULL`)
3. Le **compte utilisateur** est supprimé (`DELETE FROM user WHERE id = ?`)
4. Le **cookie remember_me** est supprimé côté client et le token invalidé en BDD

Ce choix de conception — `order.user_id NULLABLE` — est une décision délibérée prise dès la phase de modélisation pour concilier le droit à l'effacement (art. 17) avec les obligations légales de conservation des données de transaction.

7. Transferts de données vers des tiers

Tiers	Données transmises	Finalité	Localisation	Garanties
Stripe Inc.	Données de paiement (numéro de carte traité exclusivement par Stripe), montant, devise	Traitement des paiements par carte bancaire	États-Unis (Data Privacy Framework)	PCI DSS niveau 1, chiffrement TLS 1.3
Google (Gmail SMTP)	Adresse e-mail du destinataire, contenu de l'e-mail transactionnel	Envoi d'e-mails de confirmation et de réinitialisation	Union Européenne / États-Unis	Authentification SMTP + TLS, mot de passe d'application
Alwaysdata SAS	Toutes les données de l'application	Hébergement web et base de données	France (Paris)	Hébergeur français, ISO 27001, RGPD natif

Note : CYNA n'utilise pas de cookies tiers, pas de traceurs publicitaires, pas de CDN externe. Toutes les ressources statiques (Bootstrap, FontAwesome) sont servies localement.

8. Cookies utilisés

Nom	Type	Durée	Finalité
PHPSESSID	Session (fonctionnel)	Durée de la session navigateur	Authentification, panier, tokens CSRF — indispensable au fonctionnement
remember_token	Persistant (fonctionnel)	30 jours	Option "se souvenir de moi" — reconnexion automatique. Paramètres : <code>httponly</code> , <code>samesite=Lax</code>

Ces cookies sont strictement fonctionnels. Aucun consentement cookie n'est requis (exemption CNIL pour les cookies de session et d'authentification).

9. Contact — Exercice des droits

Pour exercer vos droits (accès, rectification, effacement, portabilité) :

- Via votre espace client : `/cyna/espace-client.php` (fonctionnalités en ligne)
- Via le formulaire de contact : `/cyna/contact.php`
- Par e-mail : **omarakakba91700@gmail.com**

Délai de réponse : sous 30 jours conformément à l'art. 12(3) RGPD.

En cas de réclamation non résolue, vous pouvez saisir la **CNIL** (Commission Nationale de l'Informatique et des Libertés) : www.cnil.fr

CYNA Security Platform — Politique de confidentialité RGPD — Juillet 2026
Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016
Auteur : Omar AKAKBA — BC3 CPI Bachelor DEV Full Stack — INGETIS / SUP DE VINCI